Trimarc's Take: 12 Steps for Better Password Management

trimarcsecurity.com/hub-post/trimarc-s-take-12-steps-for-better-password-management

Scott Blake July 14, 2020

Updated: Dec 13, 2024

Passwords, while serving a crucial role in identity, have unfortunately morphed into the dreaded necessary evil territory. This is easily illustrated by the breadth of its frustration. The bane of IT admins, security teams, and yes, even the everyday user, is passwords.

For users, gripes revolve around complexity, length, and duration. End-users in corporate environments are grumbling about unique (not likely), 15-character passwords that have to be changed every other month. It's a valid complaint that gets brushed to the side "for the good of security"; the irony of course being users creating easier-to-hack passwords.

On the admin side, the ever-present threat of credential theft is real. Password spraying is a common attack vector along with password reuse. In order to combat these very credible risks IT teams have been forced to implement the only tools at their disposal; the by-product unfortunately being more difficult passwords (for everyone).

Regrettably, there is no easy check-this-box solution, and passwords are not going away any time soon. With this in mind, *Trimarc's Take* is a "balancing act" approach to password management that does not overburden any of the parties involved. By following Trimarc's 12 step program, based on real-world experience and research, your Active Directory environment will be better protected, and your users will be less inclined to complain about the password requirements (or at the very least deterred from setting bad passwords).

It's important to note that the first 9 steps can be implemented with no additional cost other than time spent.

Step 1: The default/starting point. Every environment should begin here with the default domain policy (if you aren't here, get here). In Server 2008 R2 domains this means the following:

- The password must be at least 7 characters in length.
- The password must meet complexity requirements.
- A password history of 24 passwords remembered.

Step 2: Account configurations. These may seem obvious but many of Trimarc's Active Directory Security Assessments (ADSAs) flag these very issues.

All Active Directory accounts should require a password. Offending accounts can be easily identified by running the following PowerShell command:

```
Get-ADUser -Filter {PasswordNotRequired -eq $true}
```

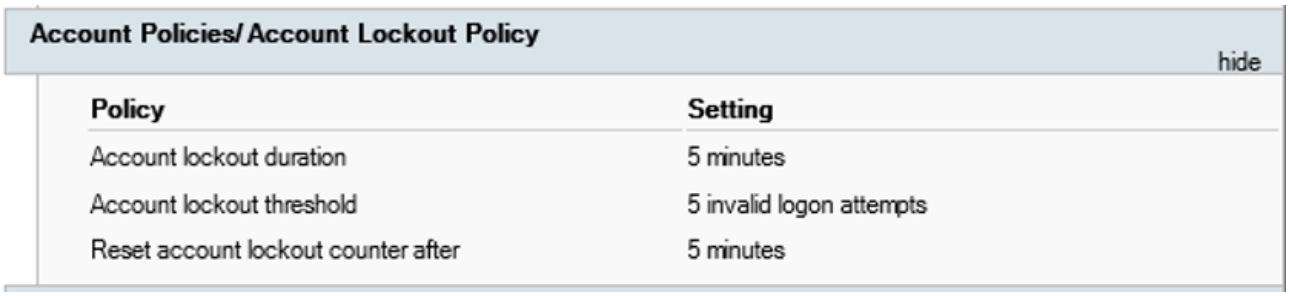
All Active Directory accounts should have a password that expires. Use the following PowerShell command to identify accounts that don't expire:

```
Get-ADUser -Filter {PasswordNeverExpires -eq $true}
```

Step 3: Password length. While only requiring a 7-character password would be nice, in reality the password length should be a minimum of 12 characters (Trimarc recommends 14 characters). This greatly increases the potential password combinations therefore making it more difficult on the attacker to guess through techniques like Password Spraying. Requiring longer passwords in this instance can reduce the risk of Active Directory account compromise.

Step 4: Account lockout configurations. Are you allowing an attacker 5 password "guesses" before lockout with a lockout period of 5 minutes (for example)? If so, that attacker can attempt 60ish passwords against 1 account in an hour (and you better believe they are not just targeting 1 account). Trimarc recommends setting:

- The "Account lockout duration" to at least 20 minutes and, if at all possible, require an admin to unlock.
- The "Account lockout threshold" in the range of 3 to 10, depending on organizational requirements.



Account Policies/ Account Lockout Policy hide

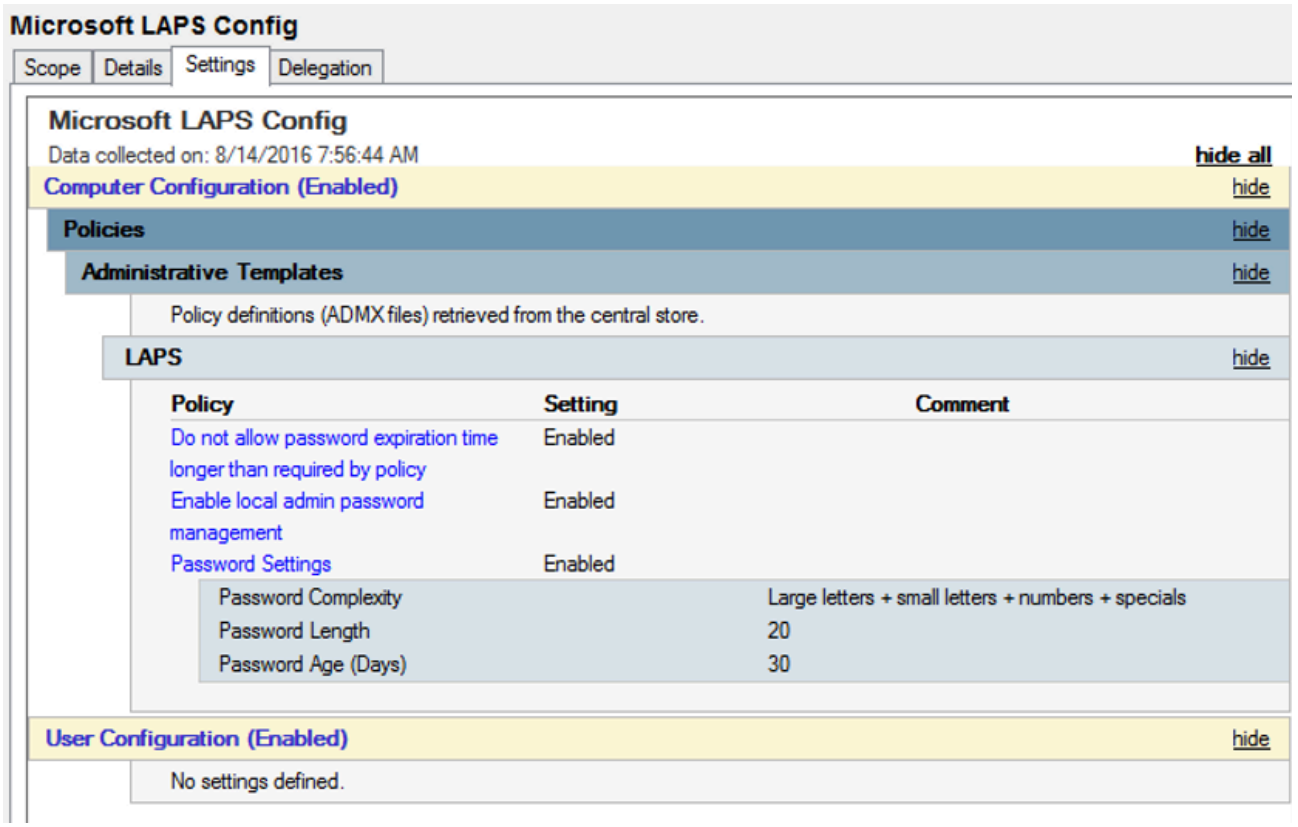
Policy	Setting
Account lockout duration	5 minutes
Account lockout threshold	5 invalid logon attempts
Reset account lockout counter after	5 minutes

Configuring LAPS via Group Policy

Step 5: Microsoft Local Administrator Password Solution (LAPS). Taking a step back from user credentials, your local Administrator account passwords on workstations and servers in the environment are of vital importance. If an attacker gains these credentials, they could potentially dump credentials for other accounts running on that machine and/or move laterally throughout the environment. LAPS is a free solution, manageable through Group Policy, that automatically rotates the local administrator account passwords.

Trimarc considers LAPS the "easy button" for dealing with the challenge of managing local Administrator account passwords. LAPS installation and configuration is straight-forward

with the caveat being to develop a good delegation plan identifying who should be able to access the LAPS managed passwords.



Configuring LAPS via Group Policy

Step 6: Fine Grained Password Policies (FGPP). FGPPs allow you to target specific Active Directory groups with increased password requirements. These are great for raising the security on highly privileged accounts while avoiding an undue burden on regular users. FGPPs can also be used when raising domain password standards for everyone and providing less restrictive standards to a small group of users. In this case, we can set the domain password policy to a minimum of 15 characters (for example) and use a FGPP for a group of users where their passwords have a 7 character minimum (for legacy system access).

Trimarc makes the following FGPP recommendations:

- A 15-character password minimum.
- Enforce password history set to 24.
- Enable password complexity.
- Maximum password age of 1 year.

Service accounts

- A 25-character password minimum.

- Enforce password history set to 24.
- Enable password complexity.
- A process in place to change the passwords at least once every 12 to 24 months or when a member of the admin team leaves the organization.
- Move as many accounts as possible to Group Managed Service Accounts.

Administration/privileged accounts

(Same as AD Administration accounts)

Step 7: Group Managed Service Accounts (GMSA). GMSAs are an excellent device for a “set it and forget it” approach to updating service account passwords. Similar to LAPS, GMSAs allow for the automatic updating of service account passwords. While this does not work across all applications, this will certainly cut down on the need to rotate every service account password every year. Be forewarned, even though GMSAs provide increased security, they aren’t bulletproof – Attacking Active Directory Group Managed Service Accounts.

Step 8: Built-In Privileged Accounts. These accounts include your KRBTGT, DSRM, and default domain Administrator (RID 500). For the vast majority of Trimarc’s these account passwords are very rarely changed, and almost never done on a regular basis. Whether through defined/enforced policies or automated means, these account passwords should be updated on a yearly basis (the KRBTGT account should be updated 2x a year).

- Automate DSRM password changes - https://docs.microsoft.com/en-us/archive/blogs/askds/ds-restore-mode-password-maintenance
- Simplify KRBTGT password changes - https://blogs.microsoft.com/microsoftsecure/2015/02/11/krbtgt-account-password-reset-scripts-now-available-for-customers/

Step 9: Auditing. Auditing should be a Blue Team’s best friend. It is next to impossible to ‘hypothetically’ build a moat and raise the drawbridge around your environment in hopes of keeping attackers out. This is why Trimarc takes an assumed breach stance and even offers an Event Monitoring Configuration Review. Think of auditing as your last line of defense. Knowing what to audit and alert on is crucial to detecting malicious activity. Here is a generalized list of items to audit:

- Authentication – NTLM & SMB.
- Advanced audit configurations through group policy settings available on Server 2008 R2 and up.

- Highly privileged group modifications (Enterprise Admin, Domain Admin, etc.).
- Highly privileged group enumeration.
- Password spraying.

Step 10: Secure Admin Workstations (SAW/PAW). Active Directory administration should ONLY be performed from purpose built administrative systems. The risk of credential theft, especially for highly privileged accounts, is too great to allow admin activities on regular, internet connected workstations or jump servers. Trimarc notes that the risk is not just with admins logging on to (or using RunAs on) regular workstations, it also applies to admins typing in credentials when remotely connecting (RDP) to systems on the network. When credentials are entered for remotely connecting to systems, an attacker could keylog/screenshot the system and extract the admin credentials from the keylog/screenshot data which would result in full AD compromise (if an AD admin's credential is exposed).

Be sure to read Microsoft's full article on Privileged Access Workstations.

Step 11: Banned Password Solution. Banned password lists are a great way to help prevent against the use of bad/known passwords in your environment. Depending on the solution implemented, these lists can be regularly updated to include passwords sourced from real-world security breaches. This is an extremely effective method to combat password spraying/reuse. Trimarc recommends using a commercial product that provides this capability since these checks are accomplished by effectively creating a shim on the Domain Controllers (leveraging the password filter dll). Microsoft's Azure AD Password Protection feature is a great example.

Another important benefit of using a Banned Password Solution, due to its ability to significantly reduce bad password use, is allowing your organization to relax some of the password requirements. For instance, instead of requiring password changes every 60 - 90 days (for example) this policy can be relaxed to every year or two. End-users everywhere will rejoice and the environment is better secured (win/win)!

Note: Password filter options that are not appropriately tested or supported may crash the Domain Controller (or all of them!).

Step 12: Two Factor/Multi Factor Authentication (MFA). The last step for better on-prem password management is MFA. Multi Factor Authentication is a beneficial tool in combating the different types of password attacks and is a must for allowing users any type of external access to the environment. It is important to note that MFA solutions do not replace passwords (outside of smartcards) and therefore should be implemented as part of a broader security plan. Furthermore, while it is possible to require MFA when connecting to a server via RDP, if an attacker can gain knowledge of the username and password for

an AD admin (for instance when the AD admin is using a regular workstation), the attacker can avoid MFA by connecting directly to the LDAP service on a Domain Controller and use this credential to run Mimikatz's DCSync to pull password hashes for all admins (& the KRBTGT password hash).

While this article's primary focus is on-prem Active Directory, MFA plays a vital role in Azure AD and password requirements. For Azure AD, with enforced MFA (not just enabled), the importance of complex passwords and password changes drop significantly provided legacy authentication is completely disabled.

*Trimarc provides a free AD Security Review PowerShell script (with guidance!) that can help identify some of the configuration issues documented in these steps i.e. password length, accounts that don't require a password, accounts that have a password that never expires, as well as a host of other common AD security issues.



By Scott W Blake

Trimarc Security Consultant with 10+ years building, configuring, and securing enterprise environments.

Trimarc provides leading expertise in security solutions including security reviews, strategy, architecture, and implementation. Our methodology leverages our internal research and custom tooling which better discovers multiple security issues attackers could exploit to compromise the environment. Trimarc security services fit between traditional

compliance/audit reviews and standard penetration testing/red teaming engagements, providing deep understanding of Microsoft and Virtualization technologies, typical security issues and misconfigurations, and provide recommendations based on our own best practices custom-tailored to balance operational and security challenges.